EXPERIMENT 12

Security Features and Governance in Zoho Creator

A practical plan for protecting data and administering the gym application

Submitted by	PRANAV SRINEVAS V	**Register No.**	241401068
Application	Gym_Membership_Management_System (Zoho Creator)	**Department**	B.Tech CSBS

1. Aim and scope

This experiment outlines security, governance and administration practices for the Gym Membership Management System in Zoho Creator: account protection, user roles, data permissions, safe Deluge scripting, controlled releases and audit review. The application holds personal data (phone numbers, e-mail addresses, dates of birth, addresses) and payment records, which need careful access control and accountability.

2. Procedure

Step	Planned activity
1. Identify sensitive data	Review the six forms: member personal details and address, payment amounts and methods, attendance history.
2. Protect accounts	Plan strong passwords and two-factor sign-in; consider single sign-on where available.
3. Assign roles	Define Administrator, Trainer and Front Desk roles using least privilege.
4. Set access rules	Check sign-in, role, form/report permission and record/field criteria.
5. Secure code	Validate inputs, guard optional values and keep credentials out of scripts.
6. Govern releases	Use Development, Stage, Production, approval and audit review steps.

3. Output – layered security

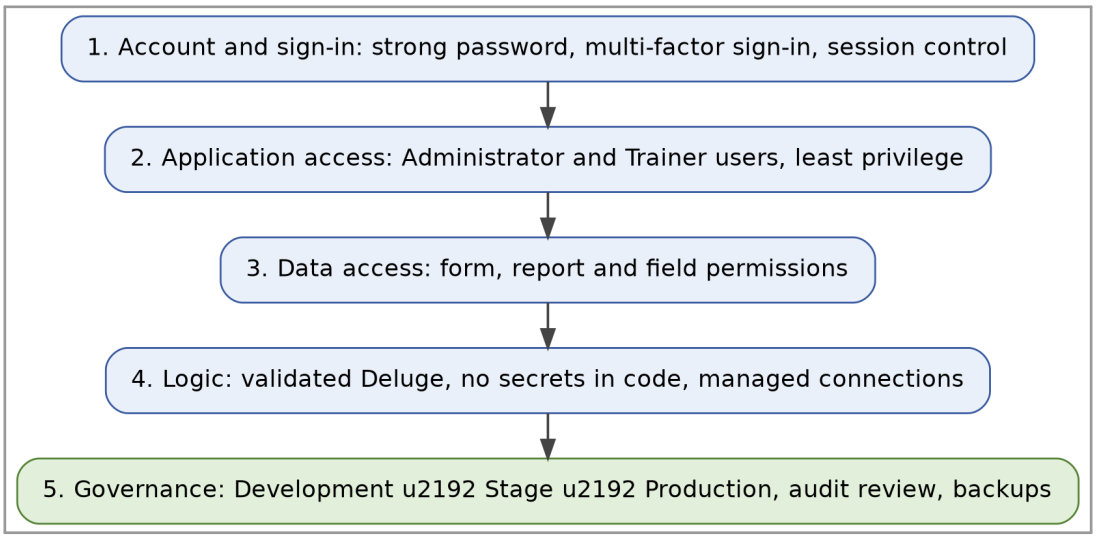


Figure 1: Layers of protection for the gym application (defence in depth).

3.1 Proposed permission matrix

This is a proposed design; actual settings should be verified in the live application.

Area	Administrator	Trainer	Front desk
Member profile	Full control	View	Create/view/edit
Membership plans, trainers	Full control	View	View
Class schedule	Full control	Create/view/edit own	View
Payments	Full control	No access	Create/view
Attendance	Full control	Create/view/edit	View
Personal fields (DOB, address)	View/edit	Limited	View/edit
Reports and exports	All reports	Class and attendance reports	Daily reports
Users and connections	Manage	No access	No access

3.2 Access-control decision flow

Check	Pass	Fail
Authentication	Check the user's role.	Deny access and request sign-in.
Role permissions	Check requested form/report access.	Deny if permission is missing.
Record and field criteria	Show only permitted records and fields.	Restrict visibility or deny the action.
Audit	Log relevant actions for review.	Review unusual or repeated failures.

3.3 Secure scripting

The member-registration script is written defensively. It calculates the end date only when a start date and a valid plan exist, never overwrites a date typed by the user, sets the status only when blank, and sends the e-mail only when an address was entered. No password or API key appears in the script; the sender is the platform's `zoho.adminuserid`. If an external service is added later, a named managed connection should be used instead of credentials in code.

```
if(input.Email_Address != null && input.Email_Address != "")
{
    // build and send the welcome e-mail only when an address exists
}
```

3.4 Change lifecycle

Develop	Test	Approve	Publish	Monitor
Build in Development.	Test in Stage with sample data.	Review changes and access.	Release to Production.	Check audit trail and errors.

3.5 Risks and controls

Risk	Example	Control
Unauthorised access	A former trainer can still view member data.	Remove access promptly; use sign-in safeguards.
Excess privilege	A trainer can see payment records.	Least privilege and separate permissions.

Risk	Example	Control
Data leakage	A report with member contacts is shared publicly.	Review sharing settings; avoid public links.
Insecure scripts	Missing validation or embedded secrets.	Guard inputs; use connections; review code.
Uncontrolled release	A live change breaks registration.	Test in Stage; approve before release.
Poor traceability	A change cannot be traced.	Review audit trails and logs.

3.6 Administration checklist

Area	Routine task	Frequency
Users	Assign roles correctly; remove leavers.	On change
Permissions	Review roles and export rights.	Quarterly
Sign-in	Check multi-factor or SSO settings.	Quarterly
Changes	Test in Stage before publishing.	Every release
Audit and recovery	Review unusual activity; test backup and CSV re-import.	Monthly

4. Final result

A security and governance plan was prepared for the gym application covering sign-in, role-based access, personal and payment data, safe scripting, staged releases, audit review and administration routines. It is a plan rather than proof that every option is enabled, so the live configuration must be verified before use. Encryption of personal fields is recommended as a future enhancement.